REVUE DE PRESSE HEBDOMADAIRE

Software Compliance

L'essentiel de la conformité des logiciels embarqués dans les produits de défense

N° 6 – Mardi 10 novembre 2026

Revue de presse hebdomadaire, tous les mardis

Les autorités européennes rappellent aux fabricants la déclaration du CRA après le sabotage de systèmes de réfrigération, que la France attribue à l'Iran ; une faille d'OpenSSH propre aux systèmes embarqués est activement exploitée ; le BIS prolonge jusqu'au 10 janvier 2027 la suspension de la règle des affiliés ; la directive sur les transferts intra-UE de produits de défense est publiée.

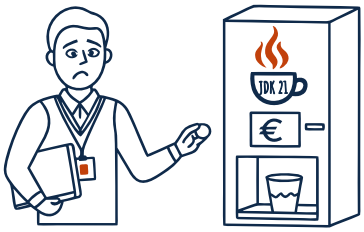
DANS CE NUMÉRO

SBOM et normes 1
Outils 2
Chaîne d'approvisionnement 2
Commerce international 3
France et UE 3
Licences 4
Glossaire 4
Agenda 4

À LA UNE

Réfrigération sabotée, le CRA rappelé aux fabricants

Des systèmes de réfrigération ont été attaqués dans plusieurs États membres ; les autorités européennes rappellent aux fabricants leur obligation de déclarer, et la France attribue le sabotage à l'Iran.



Oracle JDK 21 : les mises à jour publiées à partir du correctif trimestriel (CPU) d'octobre 2026, daté du 20 octobre, sont prévues sous licence Java SE OTN ; l'usage en production devient payant au-delà des autorisations gratuites de cette licence ; Oracle JDK 25 reste sous licence NFTC jusqu'en septembre 2028.

Jusqu'ici, JDK 21 était gratuit en production et redistribuable sous la licence NFTC (*No-Fee Terms and Conditions*). La licence OTN qui couvre ses versions 21.0.13 et suivantes en diffère substantiellement, selon Oracle : certains usages permis par les licences antérieures peuvent ne plus l'être.

Un équipement qui embarque en production ces nouveaux correctifs de JDK 21 entre dans le champ de la redevance : l'industriel doit recenser ses produits concernés, avec des SBOM qui distinguent Oracle JDK des distributions OpenJDK. Un produit maintenu plusieurs années pourrait devoir migrer vers JDK 25 ou vers une distribution OpenJDK, au prix d'une nouvelle qualification du logiciel.

EN BREF

Java 8, 11 et 17 : les versions d'Oracle JDK sont déjà proposées sous licence OTN, gratuite pour les seuls usages personnels, de développement et assimilés.

OpenJDK : Oracle publie aussi sur jdk.java.net des versions de production sous licence GPLv2 avec exception *Classpath*, aujourd'hui JDK 27.

SBOM, NORMES ET RÉFÉRENTIELS

Vingt-trois organisations demandent la citation rapide des normes IEC 62443 au titre du CRA ; Swift produit ses SBOM à la compilation ; un projet télécom européen détaille sa préparation au CRA.

AI Act : l'EN 18286, première norme harmonisée citée au Journal officiel

AI Act, première norme harmonisée : la Commission a annoncé le 19 octobre 2026 la publication au JO de la référence de l'EN 18286:2026 (système de management de la qualité), par la décision d'exécution (UE) 2026/2274 ; elle donne une présomption de conformité à l'article 17.

Élaborée par le CEN et le CENELEC, la norme suit tout le cycle de vie du système d'IA ; elle se superpose à ISO/IEC 42001 ou à ISO 9001 sans les remplacer. Elle répond au volet de la demande de normalisation du 23 juin 2025 consacré au management de la qualité, processus de surveillance après commercialisation compris.

Un fournisseur de système d'IA à haut risque peut désormais s'appuyer sur elle pour son système de management de la qualité. Le système exigé couvre notamment la notification des incidents graves et la gestion des ressources, sécurité d'approvisionnement comprise. Un fournisseur déjà tenu à un système qualité par une autre législation sectorielle de l'Union peut y intégrer ces exigences. Pour un produit à double usage qui intègre de l'IA, hors de l'exclusion défense, elle pourrait devenir une référence attendue par les clients civils.

La Commission annonce d'autres normes harmonisées avant l'application des exigences sur les systèmes à haut risque.

EN BREF

CycloneDX 2.0 : version attendue à l'automne 2026, ratification par Ecma en décembre ; le format s'étendrait aux modèles de menaces et à la provenance des composants physiques.

Normes du CRA : 17 projets de normes verticales de l'ETSI en enquête publique jusqu'à mi-novembre 2026 ; aucune norme du CRA n'est encore citée au Journal officiel.

OUTILS ET SERVICES DE CONFORMITÉ

cdxgen produit les premiers documents CycloneDX 2.0 ; Zarf annonce sa version 1.0 pour la livraison en milieu isolé ; Syft et OSV-Scanner publient de nouvelles versions.

Trivy 0.76 : nouvelles sources de correctifs et CBOM enrichi

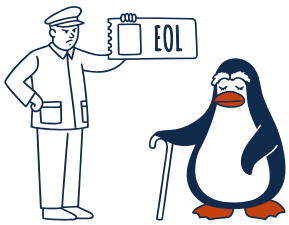
Trivy 0.76 : le scanneur d'Aqua Security détecte désormais les vulnérabilités des paquets Maven et npm corrigés par Echo, analyse les images RapidFort fondées sur Debian, Oracle Linux, Rocky Linux, AlmaLinux et Amazon Linux, et indique le niveau de sécurité nominal des algorithmes de sa nomenclature cryptographique (CBOM), fonction encore expérimentale.

Le niveau de sécurité se lit sur deux échelles : la résistance en bits aux attaques classiques et la catégorie post-quantique du NIST, de 1 à 5, ou 0 pour un algorithme qui n'en atteint aucune.

Publiée le 14 octobre, la version demande normalement une connexion Internet ; sa documentation décrit la configuration d'un réseau restreint ou entièrement isolé : les bases peuvent y être hébergées dans un registre interne, et Maven Central n'y est pas utilisable.

Les équipes qui comparent des CBOM successifs doivent prévoir le changement d'identifiant des composants DSA, la fonction pouvant évoluer sans garantie de rétrocompatibilité.

Syft 1.55 et Grype 0.121 : paquets IPK et fin de support des distributions



Syft 1.55 et Grype 0.121 : publiés le 19 octobre 2026 par Anchore, le générateur de SBOM inventorie désormais les paquets IPK, et le scanneur de vulnérabilités tient compte de la date de fin de support publiée par les distributions pour ses alertes de fin de vie.

Format du gestionnaire opkg, l'IPK reprend la structure des paquets deb : Syft le lit donc avec son catalogueur d'archives deb. Grype retrouve aussi les avis GitHub des paquets Swift Package Manager.

Les dates de fin de vie venaient jusqu'ici du projet endoflife.date ; Grype lit désormais aussi celle que déclare le fichier de version du système analysé. Passé la fin de vie, il ne signale que les vulnérabilités suivies auparavant par le mainteneur : un rapport vierge sur un tel système ne prouve pas l'absence de faille, et l'alerte doit être traitée comme une lacune de couverture.

Sur un réseau isolé, Grype exige l'import manuel d'une base récente au moins tous les cinq jours avec le réglage par défaut, faute de quoi ses analyses échouent ; Syft fonctionne sans connexion une fois la vérification de mise à jour désactivée.

Privateer : évaluation automatisée de la sécurité et de la conformité

Privateer : l'OpenSSF a annoncé le 13 octobre 2026 l'entrée dans son bac à sable (*Sandbox*) de ce cadre d'évaluation automatisée de la sécurité et de la conformité, à base d'extensions ; les contrôles déterministes passent d'abord, l'IA est facultative, et ses résultats ne déterminent pas la conformité juridique.

Chaque contrôle ressort réussi, échoué ou « à revoir », ce dernier cas laissant la décision à un humain : l'outil évalue sans bloquer les constructions non conformes, à la différence d'un moteur comme AMPEL.

Des extensions examinent dépôts, configurations, infrastructures et systèmes déployés au regard de catalogues de contrôles tenus à part, comme le référentiel OSPS Baseline.

L'option d'IA de l'extension GitHub transmet les documents déclarés au fournisseur configuré : pour un code soumis au contrôle des exportations, l'industriel doit vérifier qu'un tel transfert est autorisé. Pour les dépôts GitHub, seul le premier niveau de maturité du référentiel est recommandé : les résultats des niveaux 2 et 3, encore en développement, sont à relire.

EN BREF

Plateforme unique du CRA : lancée par l'ENISA le 11 septembre 2026, elle reçoit les déclarations des fabricants.

Chainguard : images durcies livrées avec SBOM signé, mises à jour quotidiennes et délai de 7 jours pour les CVE critiques (promesse de l'éditeur).

SÉCURITÉ DE LA CHAÎNE D'APPROVISIONNEMENT

Une faille d'OpenSSH propre aux systèmes embarqués est activement exploitée ; FreeSWITCH rejoint le même catalogue ; zlib corrige plusieurs failles.

OVHcloud : versions du CLI officiel piégées sur GitHub

OVHcloud CLI : le 19 octobre 2026, pendant environ une heure et demie, les versions v0.11 à v0.15 de l'outil, distribuées depuis son dépôt GitHub officiel, ont embarqué un binaire qui cherchait les secrets sur l'ordinateur ; une vérification de l'empreinte SHA-256 a révélé l'attaque ; la v0.16 est publiée.

Les versions touchées, parues d'avril à septembre, ont été modifiées après coup ; selon Octave Klaba, l'attaquant a utilisé le compte GitHub d'un développeur.

Les secrets recherchés peuvent être des clés d'API, des jetons d'accès, des identifiants cloud ou des clés SSH.

La version corrective porte un *tag* GitHub signé, et ses fichiers de publication sont désormais déclarés immuables.

Tout poste ou serveur qui a exécuté l'une des versions piégées doit être traité comme exposé : ses clés, jetons et mots de passe techniques sont à révoquer et à renouveler. Un dépôt officiel pouvant distribuer un logiciel malveillant, une chaîne de construction doit aussi figer l'empreinte des binaires tiers qu'elle télécharge.

GhostAction : vol d'identifiants par les GitHub Actions, puis par VS Code



GhostAction : selon GitGuardian, cité par The Hacker News, cette campagne de vol d'identifiants vise plus de 30 000 dépôts de 3 000 utilisateurs et organisations, après la compromission d'environ 1 900 comptes GitHub ; une nouvelle étape fait exécuter par VS Code un voleur d'identifiants caché dans une fausse police.

La campagne a tenté d'extraire 3 174 secrets des chaînes d'intégration de dépôts publics, au moyen d'un *workflow* déguisé en audit de sécurité ; GitHub le bloque depuis le 9 octobre.

La seconde étape échappe à ce blocage : elle se passe de GitHub Actions et persiste après la suppression du *workflow*.

Si l'exécution automatique des tâches est autorisée dans VS Code, ouvrir un dépôt piégé suffit à lancer le voleur sur le poste du développeur : ce réglage est à vérifier, et le propriétaire d'un dé-

pôt touché doit prévenir ceux qui l'ont cloné.

GitHub : alertes de paquets malveillants étendues à huit écosystèmes

Paquets malveillants : selon une étude de cas de l'OpenSSF du 16 octobre 2026, GitHub a intégré à sa base d'avis les données du dépôt *Malicious Packages* de l'OpenSSF, plus de 238 000 signalements, et couvre désormais huit écosystèmes, dont npm, PyPI, Maven et crates.io.

Ce dépôt public, lancé en octobre 2023, publie ses signalements au format OSV.

Les avis de logiciels malveillants sont publiés automatiquement, sans relecture au cas par cas, par choix délibéré.

Ces alertes restent facultatives : un dépôt dont les alertes Dependabot sont activées doit aussi les demander pour être prévenu qu'une dépendance figure parmi ces paquets.

EN BREF

Trivy, 19 mars 2026 : la version 0.69.4 et des actions GitHub de l'outil ont distribué un code volant des secrets.

Attaque du 11 mai 2026 : 404 versions malveillantes de paquets npm et PyPI, dont TanStack et Mistral AI.

COMMERCE INTERNATIONAL — Exportations et sanctions

Le BIS prolonge jusqu'au 10 janvier 2027 la suspension de la règle des affiliés ; Singapour applique sa nouvelle liste le 1er décembre ; la révision de l'USML reste ouverte aux commentaires.

UE : sanctions contre des intermédiaires qui contournent les mesures visant la Russie



Sanctions, contournement : par le règlement d'exécution (UE) 2026/2333 du 15 octobre 2026, le Conseil inscrit trois personnes et neuf entités, dont des sociétés de commerce impliquées dans l'importation en Russie de biens soumis aux mesures de l'Union.

Le texte, qui met en œuvre le règlement (UE) n° 269/2014, entre en vigueur dès sa publication au Journal officiel. Parmi les inscrits figurent Movers Group LLC, pour l'importation parallèle, et DT Inier LLC, courtier en douane qui organise des routes indirectes par des pays tiers et propose des solutions d'approvisionnement « clés en main » pour contourner les restrictions. Begler Tekstil Insaat Elektronik ve Dis Ticaret, société de commerce et de logistique, est visée pour la fourniture de produits soumis aux mesures.

Les entités sont établies en Russie, en Turquie, aux Émirats arabes unis, en Inde et aux Seychelles ; plusieurs gèrent des navires qui transportent du pétrole russe, dont certains de la flotte fantôme.

Les inscriptions visent des intermédiaires et pas seulement des entreprises russes : le filtrage des distributeurs, transitaires et clients doit intégrer la liste mise à jour. Le règlement de base gèle les avoirs des inscrits et interdit de mettre à leur disposition, directement ou indirectement, des fonds ou des ressources économiques, actifs incorporels compris. Livrer un logiciel, une licence ou une mise à jour à un intermédiaire inscrit pourrait constituer une violation des mesures de l'Union.

Royaume-Uni : licences générales d'exportation élargies

Royaume-Uni, licences générales : depuis le 14 octobre 2026, l'ECJU étend la licence générale ouverte (OGEL) *dual-use* à douze nouvelles destinations et élargit les deux OGEL des biens, logiciels et technologies militaires, la plus large s'ouvrant notamment à la Pologne, à la Grèce et à la Corée du Sud.

L'OGEL *dual-use* couvre des équipements aéronautiques et maritimes, les technologies de l'information, les semi-conducteurs avancés et le quantique. Parmi les douze nouvelles destinations figurent Bahreïn, le Maroc, Oman, les Philippines et le Qatar.

L'OGEL militaire réservée aux utilisateurs finaux gouvernementaux ou de l'OTAN s'ouvre au Chili, au Monténégro, à la Jordanie, au Koweït et à la Macédoine du Nord, entre autres.

Une entité britannique peut ainsi exporter vers ces pays sans demande individuelle, si elle respecte les conditions des OGEL ; l'ECJU estime éviter plus de 800 demandes par an et pouvoir examiner plus vite les licences les plus sensibles. Pour l'OGEL *dual-use*, l'exportateur doit s'enregistrer sur SPIRE, le système de licences en ligne, avant le premier usage, en indiquant où l'ECJU peut inspecter ses registres, et, pour les exportations concernées, porter la référence de la licence dans la déclaration en douane. Sans avis de classement officiel, l'exportateur devrait toutefois établir lui-même que ses biens entrent dans le champ de ces licences.

EN BREF

Sanctions, 22e paquet : adopté le 12 octobre 2026, il inscrit 1 569 personnes et entités, dont des fournisseurs de composants du complexe militaro-industriel russe.

Sanctions : le 21e paquet de l'UE contre la Russie (23 juillet 2026) laisse jusqu'au 25 octobre pour exécuter certains contrats antérieurs.

Royaume-Uni, classement : le service CLC de l'ECJU reste suspendu depuis le 12 octobre 2026, sans date de reprise.

***Dual-use* UE** : le règlement délégué du 14 septembre 2026 met à jour l'annexe I et étend les contrôles sur les logiciels de nouveaux équipements semi-conducteurs.

CMMC : la suspension de la phase 2, décidée le 13 juillet 2026, reste sans date de reprise ; NIST SP 800-171 et DFARS 252.204-7012 restent applicables.

ITAR-free : Honeywell a chargé 1 000 ingénieurs en Pologne et en Tchéquie de concevoir des technologies non-ITAR face à la demande européenne.

FRANCE ET UE — NIS2, défense, IA

La directive sur les transferts intra-UE de produits de défense est publiée au Journal officiel ; l'Assemblée nationale examine enfin la loi Résilience.

Transferts intra-UE de produits de défense : la directive 2026/2383 publiée

Mise à jour, Omnibus défense : la directive (UE) 2026/2383 sur la simplification des transferts intra-UE de produits de défense a été publiée au Journal officiel le 3 novembre 2026 ; ses licences générales de transfert s'appliqueront aussi aux transferts immatériels de logiciels et de technologie ; transposition au plus tard le 24 novembre 2027.

Le texte modifie deux directives de 2009, sur les transferts de produits liés à la défense et sur les marchés publics de défense. Il entre en vigueur le 23 novembre ; les mesures nationales s'appliqueront à partir du 24 février 2028.

Une nouvelle licence générale couvre les transferts entre entreprises certifiées. Selon la Natio-

nal Law Review, chaque État membre doit publier des licences générales pour trois catégories supplémentaires.

Jusqu'à la transposition, le régime français actuel s'applique. L'industriel peut dès maintenant recenser ses transferts de logiciels et de données techniques vers ses partenaires européens et vérifier sa certification. Elle pourrait ouvrir la voie à des transferts sans licence individuelle.

Loi Résilience : l'examen en séance commence à l'Assemblée nationale

Mise à jour, loi Résilience : l'Assemblée nationale examine en séance publique, depuis le 9 novembre 2026, le projet de loi qui transpose notamment NIS2, sur le texte de sa commission spéciale ; 407 amendements ont été déposés et l'examen est prévu jusqu'au 13 novembre.

Les députés travaillent sur le texte de leur commission spéciale. Adopté par le Sénat le 12 mars 2025, le projet avait été retiré de l'ordre du jour de l'Assemblée en octobre.

Selon LCP, le nombre de secteurs régulés passerait de six à 17, et celui des entités régulées de 500 à près de 15 000. Les sanctions pourraient atteindre 10 millions d'euros ou 2 % du chiffre d'affaires mondial.

L'industriel doit vérifier s'il serait entité essentielle ou importante et suivre les exigences que ses clients opérateurs pourraient lui répercuter. Les mesures de sécurité de la chaîne d'approvisionnement pourraient atteindre ses produits logiciels.

EN BREF

AI Act, normes harmonisées : selon le CEN-CENELEC, la demande de normalisation révisée fixe leur échéance à février 2027.

SAFE : le 29 octobre 2026, la Commission a ouvert un deuxième appel de 21,3 milliards d'euros de prêts pour l'achat de produits de défense.

LICENCES OPEN SOURCE ET LOGICIELS EMBARQUÉS

OpenChain publie un cadre de SBOM pour l'automobile qui exige la licence conclue et l'avis de copyright de chaque composant ; les contentieux Vizio et Bambu Lab restent ouverts.

Russie : une suite fondée sur LibreOffice refusée au registre des logiciels nationaux

Russie, droits sur un logiciel dérivé : le 7 octobre 2026, le tribunal d'arbitrage de Moscou a validé le refus du ministère du Numérique d'inscrire « Free Office », de BaseALT, au registre des logiciels russes ; l'éditeur ne détenait pas les droits sur LibreOffice, composant central.

Pour le tribunal, la localisation russe, les dictionnaires et l'intégration de la signature électronique ne suffisaient pas à fonder une propriété indépendante. Selon l'avocat Denis Dorotenko, cinq des sept programmes de la suite sont des développements tiers sous licence ouverte : si le titulaire de l'un d'eux modifiait sa licence ou y mettait fin, l'usage de l'ensemble deviendrait illicite. L'éditeur décrit un ensemble comprenant des suites bureautiques, un client de messagerie et le navigateur Chromium adapté à la cryptographie russe GOST.

L'inscription a des effets concrets : distinct d'un dépôt de droits d'auteur, le registre ouvre des avantages fiscaux sur les licences et les cessions de droits, et facilite l'accès aux marchés publics. Le jugement aborde les licences *copyleft*, la norme d'État russe sur la documentation logicielle et la modification de logiciels.

La décision ne vaut qu'en Russie et peut faire l'objet d'un appel ; elle invite à documenter la part de code propre d'un produit dérivé de composants open source. Une déclaration d'origine ou de propriété d'un logiciel, demandée par un client ou par un programme de production nationale, pourrait être contestée si le produit repose surtout sur de tels composants ; selon Heather Meeker, la décision pourrait peser sur de futurs litiges portant sur le respect des licences open source en Russie.

EN BREF

GPL, SFC contre Vizio : le procès est indiqué par la SFC pour fin 2026 ; aucun verdict n'a été relevé dans les sources consultées.

AGPLv3 : la SFC a publié le 18 mai 2026 sa réponse aux violations de l'AGPLv3 par Bambu Lab ; l'enquête est en cours.

AGENDA

Dates à surveiller

NOV. 2026 — EXPORT UE
Règlement délégué adopté le 14 septembre 2026 ; publication au JO après deux mois d'examen du Parlement européen et du Conseil, sauf objection

23 NOV. — EXPORT UE
Vingtième jour après la publication au JO du 3 novembre 2026 ; transposition au plus tard le 24 novembre 2027

30 NOV. — EXPORT ÉTATS-UNIS
Projet publié le 1er octobre 2026 : retrait de certains articles de la liste, définitions révisées, nouvelle exemption de licence

DÉC. 2026 — EXPORT SINGAPOUR
Ordonnance publiée le 1er octobre 2026, fondée sur les listes 2025 des régimes multilatéraux ; transferts électroniques de technologie compris

DÉC. 2026 — EXPORT ROYAUME-UNI
Mise à jour des listes militaire et dual-use (biens, logiciels, technologies) annoncée par l'avis aux exportateurs 2026/24

9 DÉC. — RESPONSABILITÉ PRODUIT
Transposition de la directive (UE) 2024/2853, qui inclut le logiciel ; elle s'applique aux produits mis sur le marché à partir de cette date

JANV. 2027 — EXPORT ÉTATS-UNIS
Suspension prolongée par la règle finale du BIS publiée au Federal Register le 9 novembre 2026

DÉC. 2027 — CRA
Application complète du CRA ; selon l'ENISA, les gestionnaires de logiciels open source sont soumis à la déclaration à la même date

GLOSSAIRE

Sigles et termes cités

CEN-CENELEC Comités européens de normalisation (CEN) et de normalisation électrotechnique (CENELEC)

CLI Command-Line Interface

CPU Critical Patch Update

CRA Cyber Resilience Act

ECJU Export Control Joint Unit

GitHub Plateforme collaborative de développement logiciel

Grype Scanneur open source de vulnérabilités

IPK Format de paquet logiciel utilisé notamment par des distributions Linux embarquées

Java SE Java Platform, Standard Edition

JDK Java Development Kit

NFTC Oracle No-Fee Terms and Conditions

npm Gestionnaire de paquets de Node.js et registre où se publient les modules JavaScript

OGEL Open General Export Licence

OTN Oracle Technology Network License Agreement for Java SE

SHA-256 Fonction de hachage cryptographique

SSH Secure Shell

VS Code Visual Studio Code

Software Compliance
Revue de presse hebdomadaire, N° 6 du 10 novembre 2026.
Rédigée par une intelligence artificielle (Claude Opus 5.5), peut comporter des erreurs : pensez à croiser vos sources.
Édition en ligne avec sources : revue.dejeun.es/2026-11-10
© 2026 Rodolphe Dejeunes, publié sous licence CC BY 4.0.